

**Conception et veille active d'une infrastructure
Windows virtualisée – NEOTECH Solutions
Projet de Penetration Testing et Hardening**

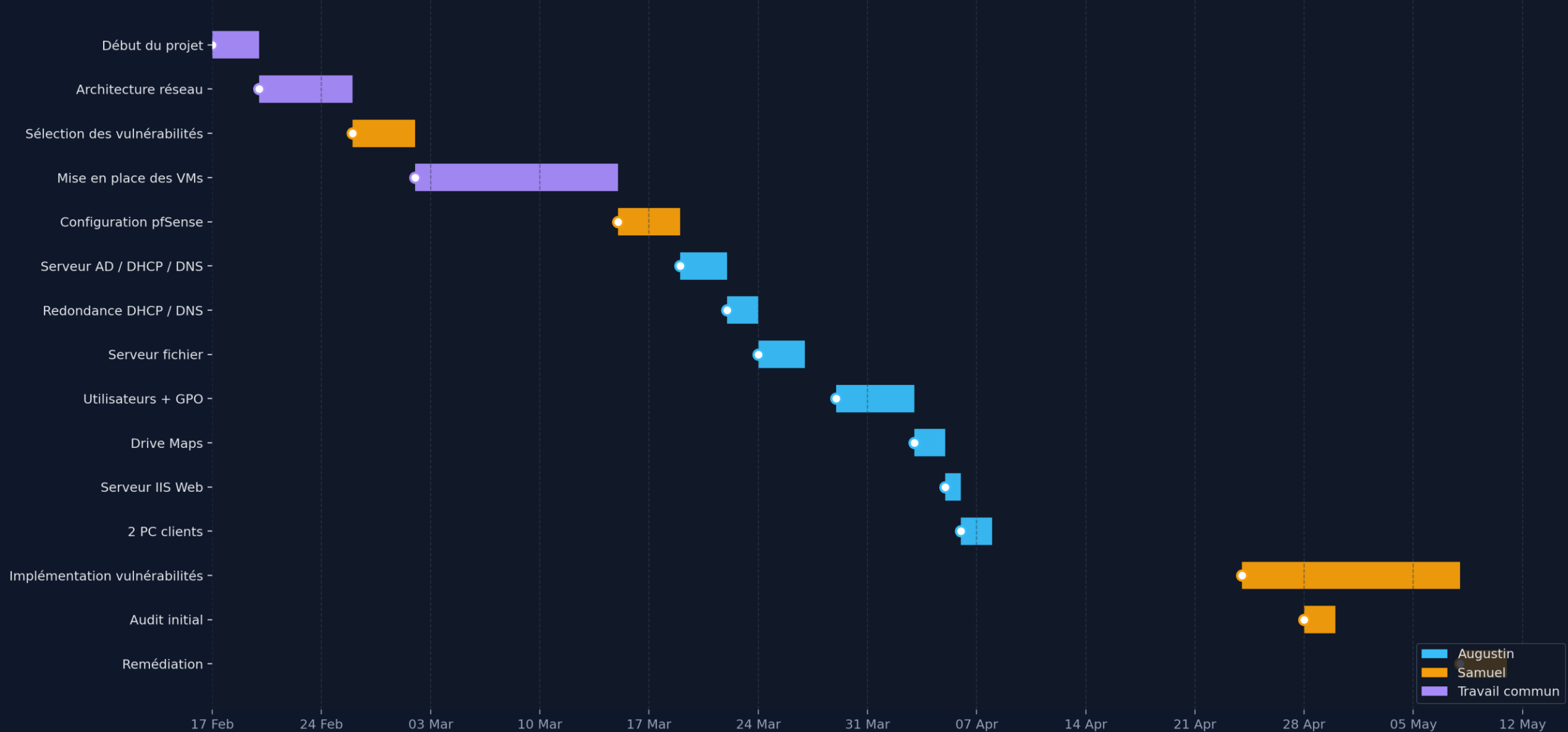
**EKPEVI Kossi Augustin & MEYISSO Samuel
Emmanuel**

**Bachelor Cybersécurité & Hacking Éthique
Projet B1 – SYS&OFF12_2025-2026
École 89**

**Fin mai 2026
Professeur référent : Monsieur Eddy MOZAR**



Projet SYS12 / OFF12 - Diagramme de Gantt



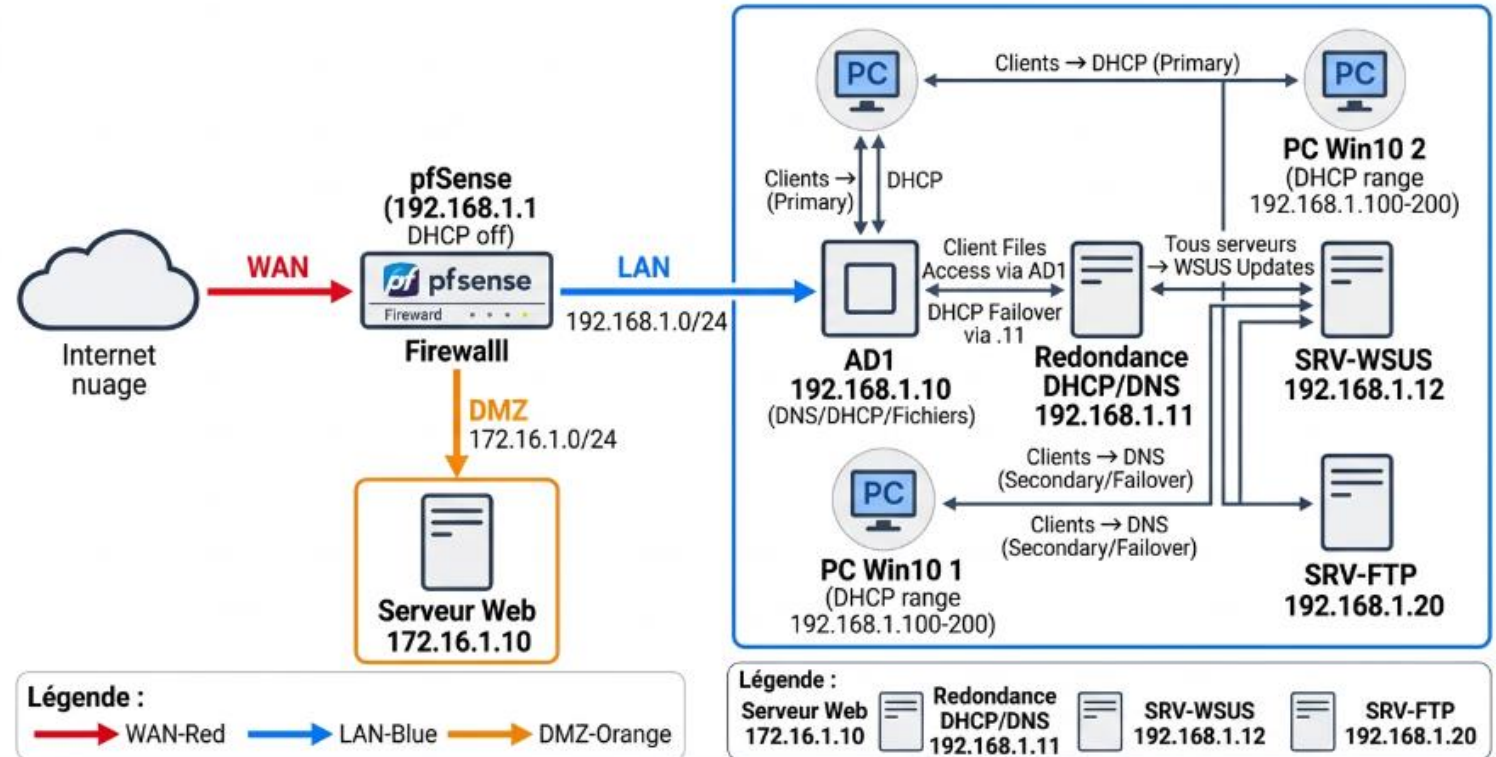
Période: février → mai 2026

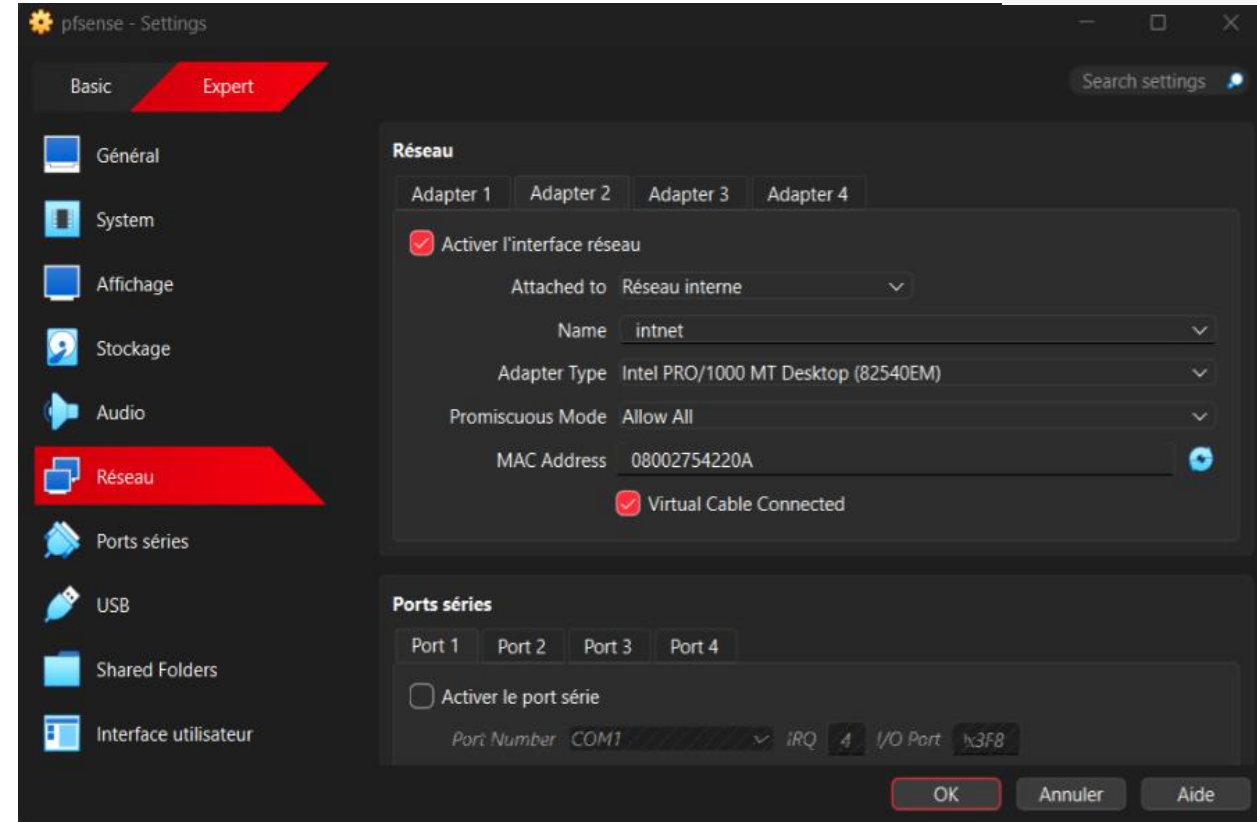
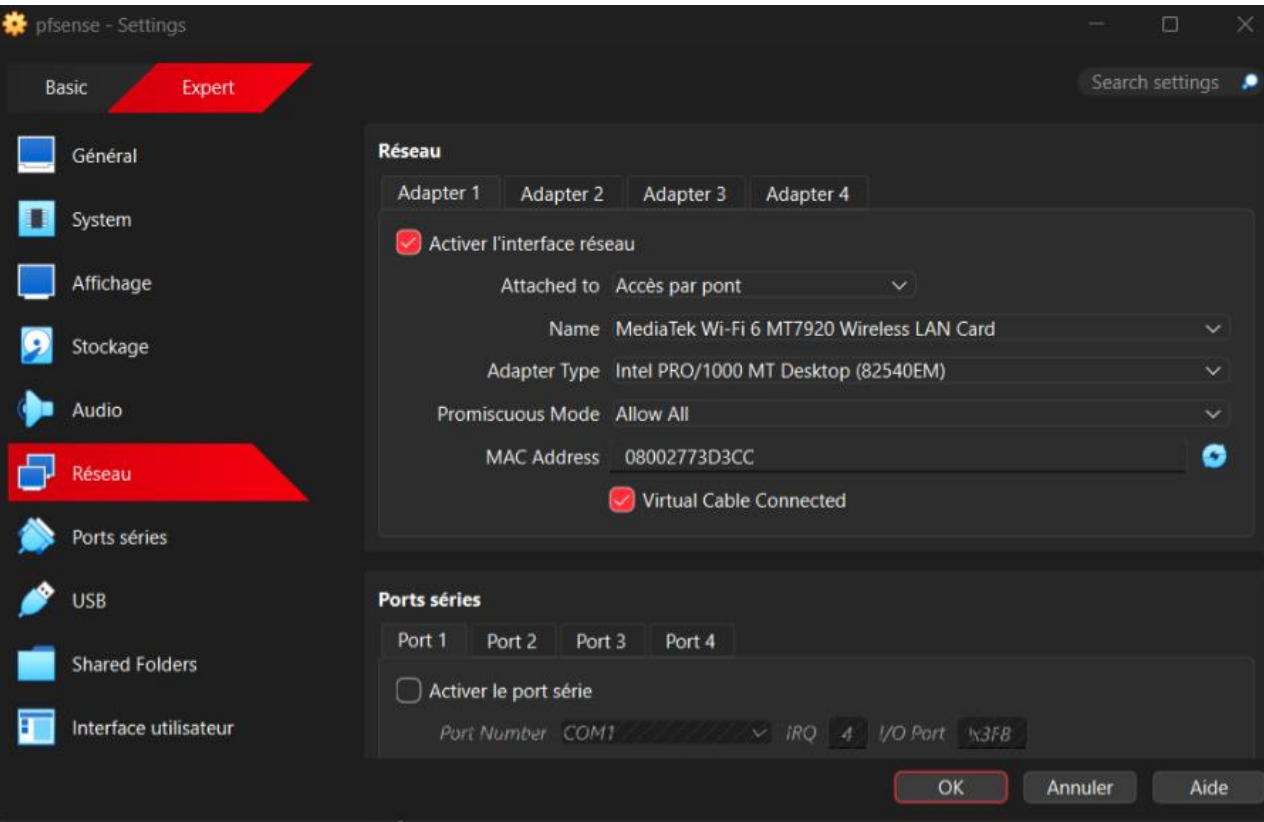
Titre : Architecture réseau de l'infrastructure NEOTECH

L'infrastructure repose sur un réseau virtualisé segmenté autour d'un pare-feu pfSense.

- pfSense assure le routage, le contrôle des flux et l'accès au réseau interne.
- Les serveurs Windows et les postes clients communiquent dans une topologie centralisée et maîtrisée.

SCHÉMA RÉSEAU PROJET SYS12 CYBERSÉCURITÉ





Configuration des deux interfaces réseau de pfSense dans VirtualBox (WAN vers Internet, LAN vers réseau interne)

Basic

Expert



Général



System



Affichage



Stockage



Audio



Réseau



Ports séries



USB



Shared Folders



Interface utilisateur

Réseau

Adapter 1

Adapter 2

Adapter 3

Adapter 4

☒ Activer l'interface réseau

Attached to Réseau interne

Name intnet

Adapter Type Intel PRO/1000 MT Desktop

Promiscuous Mode Refuser

MAC Address 080027016C90

☒ Virtual Cable Connected

Ports séries

Port 1

Port 2

Port 3

Port 4

☐ Activer le port série

Port Number COM1 IRQ 4 I/O Port 3F8

- Configuration réseau SRV-AD-Primary.

OK

Annuler

Basic

Expert



Général



System



Affichage



Stockage



Audio



Réseau



Ports séries



USB



Shared Folders



Interface utilisateur

Réseau

Adapter 1

Adapter 2

Adapter 3

Adapter 4

☒ Activer l'interface réseau

Attached to Réseau interne

Name intrnet

Adapter Type Intel PRO/1000 MT Desktop

Promiscuous Mode Refuser

MAC Address 080027016C91

☒ Virtual Cable Connected

Ports séries

Port 1

Port 2

Port 3

Port 4

☐ Activer le port série

Port Number COM1 IRQ 4 I/O Port 3F8

Configuration réseau SRV-AD- Secondary

Click to add text



OK

Annuler

Titre : Configuration pfSense



PFSense sépare le réseau
interne Neotech d'internet.



L'interface LAN est configurée
en 192.168.1.1/24 avec DHCP
temporaire au départ.



Les tests montrent une
connectivité fonctionnelle
entre client, pare-feu et
internet.

Attribution automatique des interfaces physiques (em0=WAN, em1=LAN)

```
VirtualBox Virtual Machine - Netgate Device ID: caf86d9ad7be325c9973  
  
*** Welcome to pfSense 2.6.0-RELEASE (amd64) on pfSense ***  
  
WAN (wan)      -> em0      -> v4/DHCP4: 192.168.0.20/24  
LAN (lan)      -> em1      -> v4: 192.168.1.1/24
```

- Test de connectivité depuis un poste client : IP obtenue par DHCP et accès Internet via Accès par pont.

```
PS C:\Users\vboxuser> ping 192.168.1.1  
  
Envoi d'une requête 'Ping' 192.168.1.1 avec 32 octets de données :  
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64  
Réponse de 192.168.1.1 : octets=32 temps=2 ms TTL=64  
Réponse de 192.168.1.1 : octets=32 temps=3 ms TTL=64  
Réponse de 192.168.1.1 : octets=32 temps=2 ms TTL=64  
  
Statistiques Ping pour 192.168.1.1:  
.....Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),  
Durée approximative des boucles en millisecondes :  
Minimum = 1ms, Maximum = 3ms, Moyenne = 2ms  
PS C:\Users\vboxuser>
```

Le client ping le pare feu pfSense

```
PS C:\Users\vboxuser> ping 8.8.8.8
```

```
Envoi d'une requête 'Ping' 8.8.8.8 avec 32 octets de données :
```

```
Réponse de 8.8.8.8 : octets=32 temps=37 ms TTL=115
```

```
Réponse de 8.8.8.8 : octets=32 temps=121 ms TTL=115
```

```
Réponse de 8.8.8.8 : octets=32 temps=17 ms TTL=115
```

```
Réponse de 8.8.8.8 : octets=32 temps=17 ms TTL=115
```

```
Statistiques Ping pour 8.8.8.8:
```

```
Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
```

```
Durée approximative des boucles en millisecondes :
```

```
Minimum = 17ms, Maximum = 121ms, Moyenne = 48ms
```

```
PS C:\Users\vboxuser>
```

Connexion internet
via le pare-
feu pfsense établie

pfSense.labo.test - Status: Dashboard X

Non sécurisé https://192.168.1.1

pfSense
COMMUNITY EDITION

Status / Dashboard

System Information

Name	pfSense.labo.test
User	admin@192.168.1.10 (Local Database)
System	VirtualBox Virtual Machine Netgate Device ID: caf86d9ad7be325c9973
BIOS	Vendor: innotek GmbH Version: VirtualBox Release Date: Fri Dec 1 2006
Version	2.6.0-RELEASE (amd64) built on Mon Jan 31 19:57:53 UTC 2022 FreeBSD 12.3-STABLE Version 2.7.0 is available. Version information updated at Thu Mar 19 2:19:38 UTC 2026
CPU Type	AMD Ryzen 7 5825U with Radeon Graphics 2 CPUs: 1 package(s) x 2 core(s) AES-NI CPU Crypto: Yes (inactive) QAT Crypto: No



Connexion à la
page pfSense via
le pc client réussie

Click to add text



Titre : Active Directory, DNS et DHCP



Le domaine **novabike.local** est créé sur le serveur principal avec AD DS et DNS.



Le serveur DHCP distribue les adresses et fournit routeur et DNS aux clients.



Les serveurs Windows Server 2022 sont configurés avec IP statiques et reliés à pfSense.

Afficher/Modifier une relation de basculement ? X

Modifiez les paramètres relatifs à la relation de basculement :

Nom de la relation : win-kpd2sbs9vfg.novabike.local-192.168.1.1

État de ce serveur : Normale
Remplacer par le partenaire hors service

État du serveur partenaire : Normale

☐ Activer l'authentification du message

Secret partagé :

☒ Intervalle de basculement d'état : 15 minutes

Délai de transition maximal du client (MCLT) : 1 heures 0 minutes

☒ Mode d'équilibrage de charge

Serveur local : 60 %

Serveur partenaire : 40 %

☐ Mode du serveur de secours

Rôle de ce serveur : Actif

Adresses réservées pour le serveur de secours : 5 %

OK Annuler

- Config failover DHCP.

```
PS C:\Users\vboxuser> ipconfig /renew
```

```
Configuration IP de Windows
```

```
Carte Ethernet Ethernet :
```

```
Suffixe DNS propre à la connexion. . . : labo.test  
Adresse IPv6 de liaison locale. . . . . : fe80::314e:e8ea:ad5a:9a12%6  
Adresse IPv4. . . . . : 192.168.1.10  
Masque de sous-réseau. . . . . : 255.255.255.0  
Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%6  
192.168.1.1
```

```
PS C:\Users\vboxuser> █
```

**Adresse pc connecté au
serveur DHCP principal**

```
PS C:\Users\voobuser> ipconfig /renew
```

```
Configuration IP de Windows
```

```
Carte Ethernet Ethernet :
```

```
Suffixe DNS propre à la connexion. . . : labo.test  
Adresse IPv6 de liaison locale. . . . : fe80::314e:e8ea:ad5a:9a12%6  
Adresse IPv4. . . . . : 192.168.1.10  
Masque de sous-réseau. . . . . : 255.255.255.0  
Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%6  
                                192.168.1.1
```

**Le pc n'a plus d'adresse ip quand on
a éteint le serveur DHCP principal**

```
PS C:\Users\vboxuser> ipconfig /renew
```

```
Configuration IP de Windows
```

```
Carte Ethernet Ethernet :
```

```
Suffixe DNS propre à la connexion. . . : labo.test
Adresse IPv6 de liaison locale. . . . : fe80::314e:e8ea:ad5a:9a12%6
Adresse IPv4. . . . . : 192.168.1.10
Masque de sous-réseau. . . . . : 255.255.255.0
Passerelle par défaut. . . . . : fe80::a00:27ff:fe54:220a%6
                                192.168.1.1
```

Quand on a fait un `ipconfig /renew` le pc a eu
une adresse ip donner par le serveur dhcp de
redondance

```
PS C:\Users\vboxuser> ping 192.168.1.1
```

```
Envoi d'une requête 'Ping' 192.168.1.1 avec 32 octets de données :
```

```
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
```

```
Réponse de 192.168.1.1 : octets=32 temps=2 ms TTL=64
```

```
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
```

```
Réponse de 192.168.1.1 : octets=32 temps=1 ms TTL=64
```

```
Statistiques Ping pour 192.168.1.1:
```

```
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
```

```
Durée approximative des boucles en millisecondes :
```

```
    Minimum = 1ms, Maximum = 2ms, Moyenne = 1ms
```

Et le pc arrive à ping le parefeu

Titre : Structuration Active Directory et application des stratégies

L'annuaire Active Directory a été organisé par unités d'organisation, groupes et comptes utilisateurs.

Cette structuration permet une administration claire des droits et des ressources.

Des stratégies de groupe ont été appliquées pour renforcer la sécurité, notamment sur les mots de passe.

Nouvel objet - Utilisateur

Créer dans : novabike.local/SYS12

Mot de passe :

Confirmer le mot de passe :

☒ L'utilisateur doit changer le mot de passe à la prochaine ouverture de session

☐ L'utilisateur ne peut pas changer de mot de passe

☐ Le mot de passe n'expire jamais

☐ Le compte est désactivé

< Précédent Suivant > Annuler

 dir .general	Utilisateur
 tech .01	Utilisateur
 commercial ...	Utilisateur
 support .01	Utilisateur
 srv .admin	Utilisateur
 poste .01	Utilisateur

Utilisateurs et ordinateurs Active Directory

Fichier Action Affichage ?

Nom	Type
GG_Comme...	Groupe de séc..
GG_Direction	Groupe de séc..
GG_Postes	Groupe de séc..
GG_Serveurs	Groupe de séc..
GG_Support	Groupe de séc..
GG_Technique	Groupe de séc..

Les captures
montrent
l'organisation
logique de
l'annuaire et
l'application
d'une politique
de mot de passe.

Utilisateur	Groupe
dir.general	GG_Direction
tech.01	GG_Technique
commercial.01	GG_Commercial
support.01	GG_Support
srv.admin	GG_Serveurs
poste.01	GG_Postes

Les règles du gpo émises



La taille minimum du mot de passe : 8.



Le mot de pass doit Etre complexe : Activé.



Maximum de validité du mot de passe : 60 jours.



Nombre de tentative : 5.

Titre : Partage de fichiers et accès centralisé aux ressources



Un partage réseau a été configuré pour centraliser les documents de travail.



Le lecteur réseau Z: est déployé automatiquement pour simplifier l'accès des utilisateurs.



Cette configuration améliore l'usage quotidien tout en gardant un contrôle des permissions.

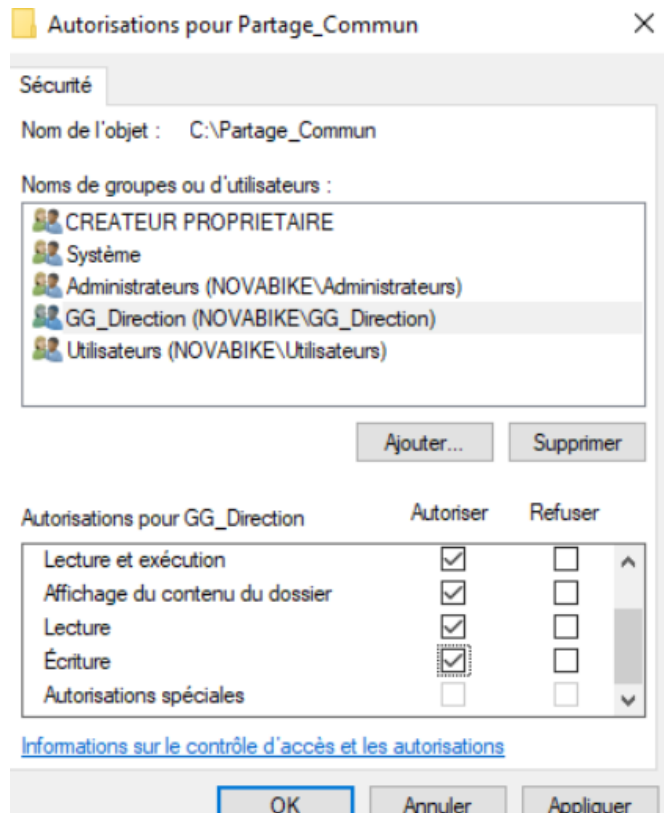
La preuve montre le partage publié côté serveur et son mappage automatique côté poste client.

```
PS C:\Users\Administrateur> New-Item -Path "C:\Partage_Commune" -ItemType Directory

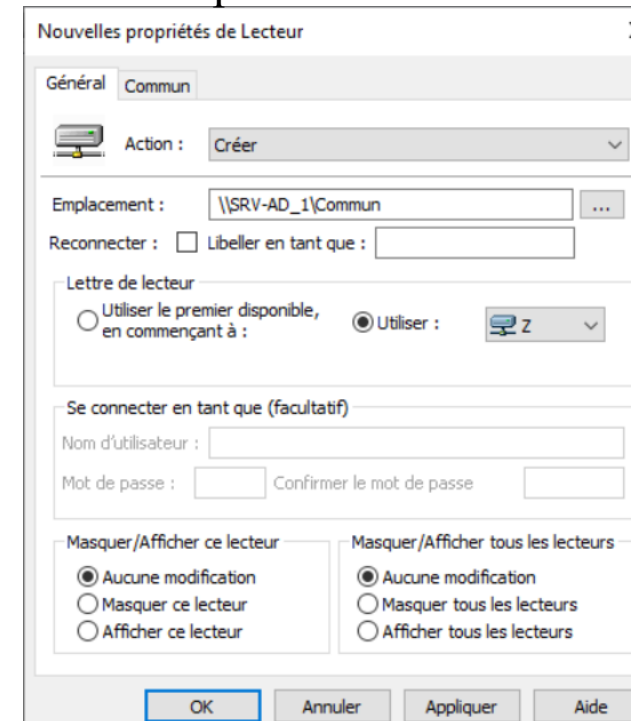
Répertoire : C:\

Mode                LastWriteTime         Length Name
----                -
d-----          03/04/2026    14:53             Partage_Commune
```

Get-SmbShare ou net share montrant Commun,



Écran Drive Maps avec le lecteur Z: configuré.

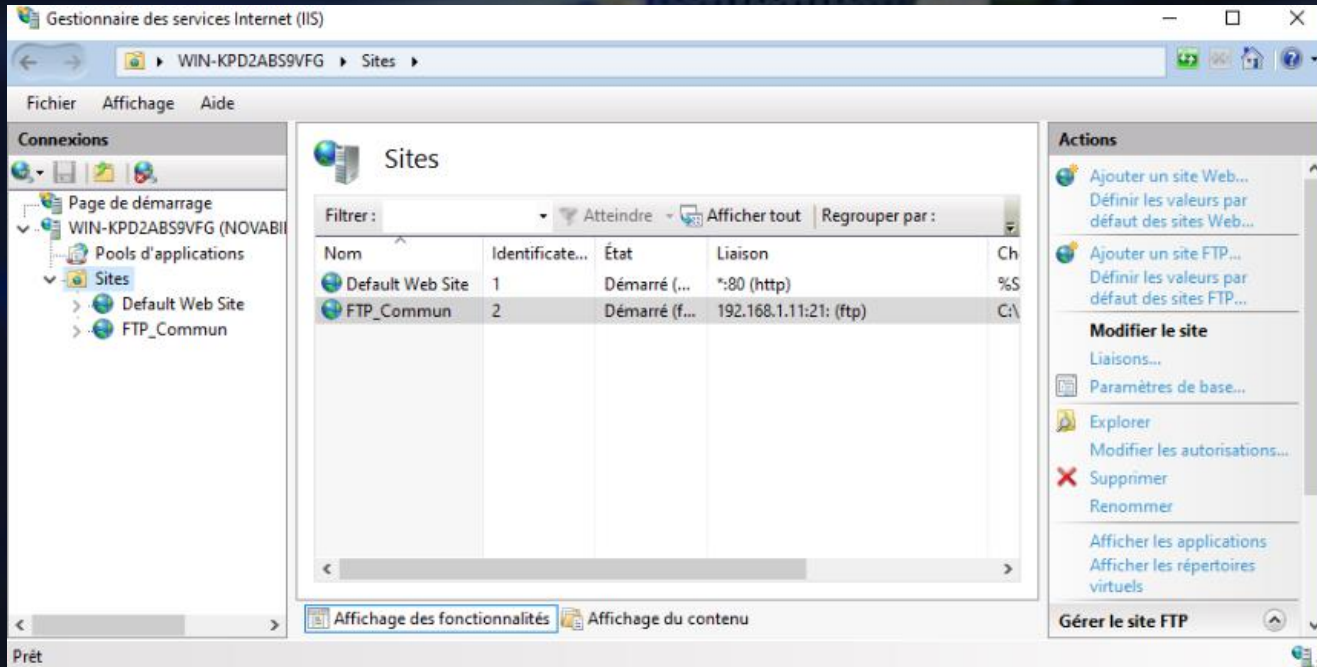


propriétés de sécurité du dossier avec tes groupes AD.

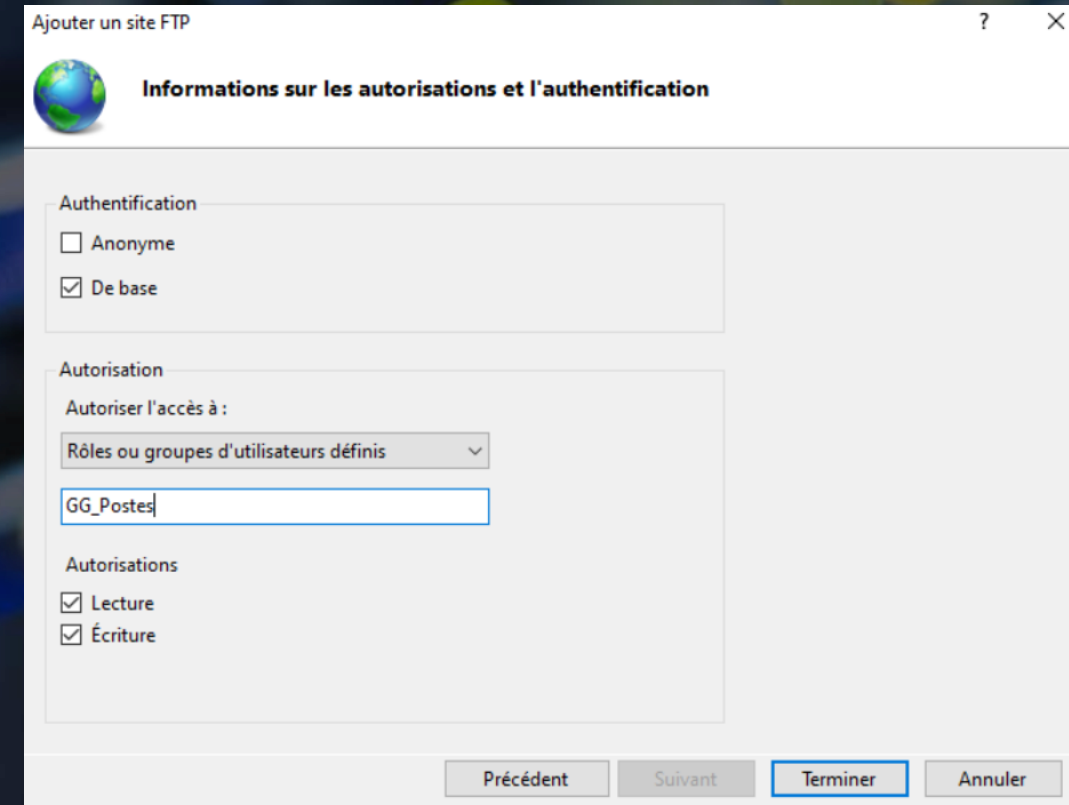
Titre : Mise à disposition de services applicatifs

Le serveur héberge des services web et de transfert de fichiers via IIS et FTP.

Ces services permettent de simuler des usages réels au sein d'une infrastructure d'entreprise.
Leur déploiement a également servi de base à l'analyse d'exposition et aux tests de sécurité.

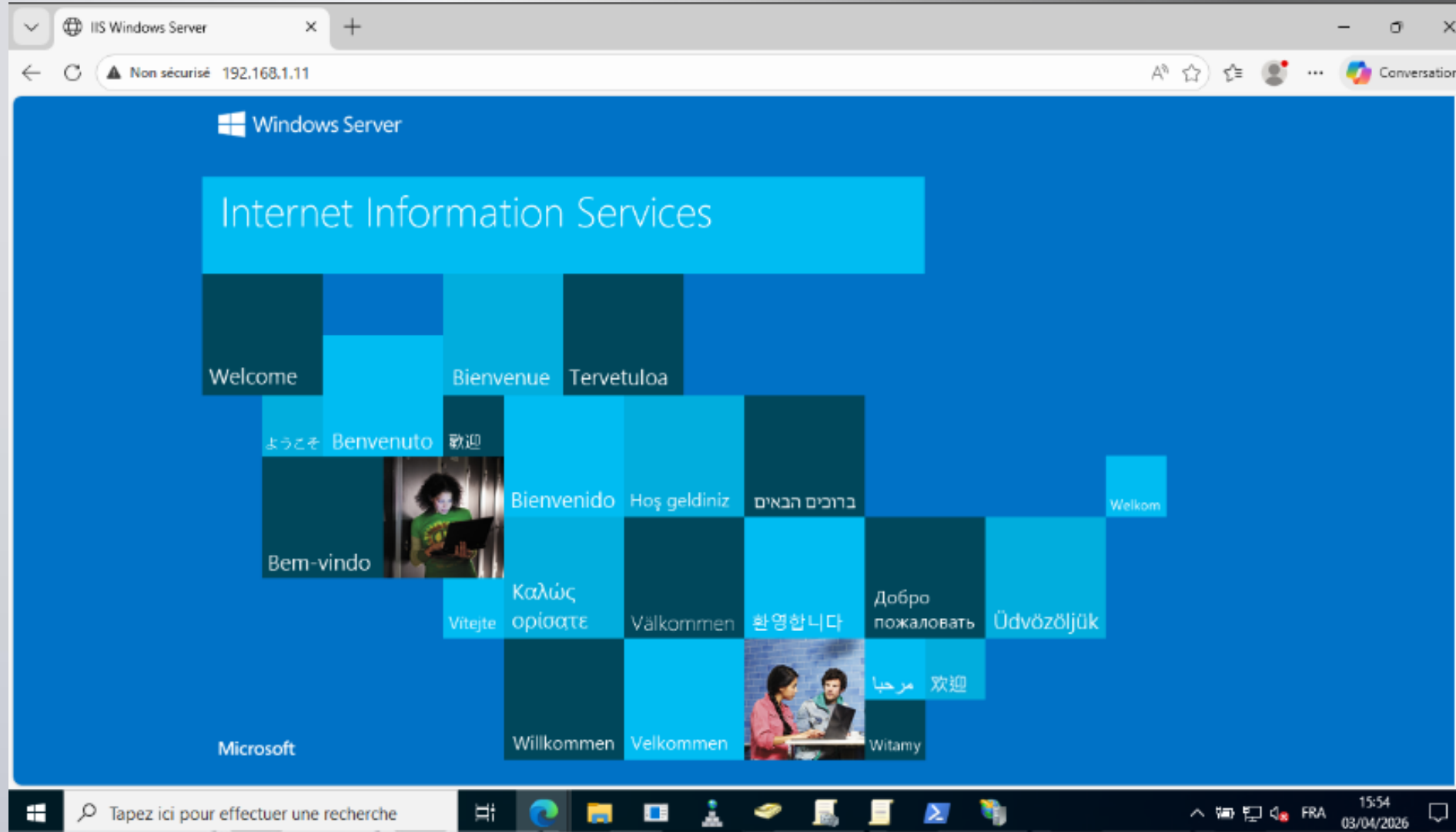


IIS Manager avec FTP_Communic dans Sites,



Fenêtre de configuration du site FTP.

Les captures illustrent la configuration du service et la validation de son accessibilité.



Page IIS dans le navigateur.

Titre : Gestion centralisée des mises à jour avec WSUS



Un serveur WSUS a été déployé pour centraliser la gestion des correctifs.

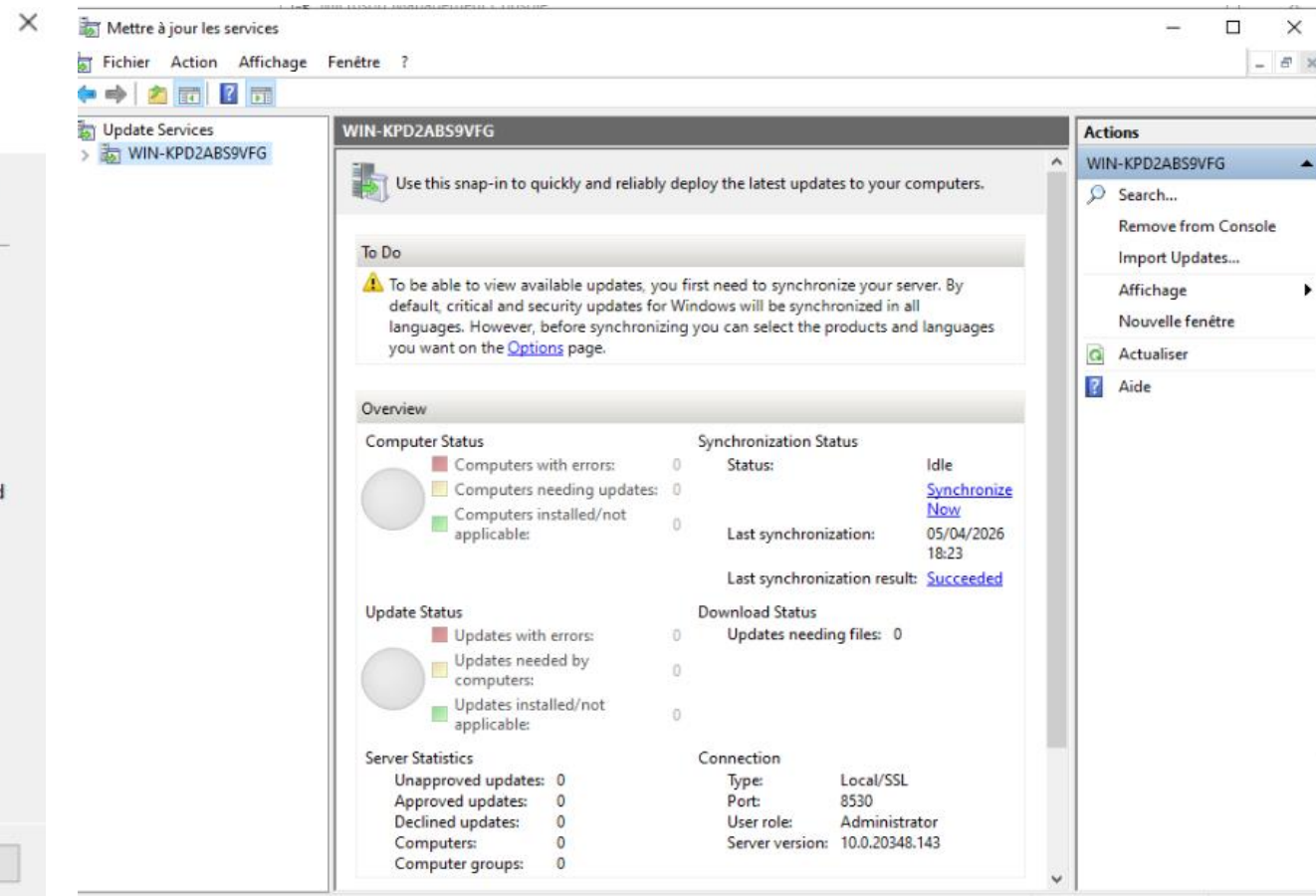
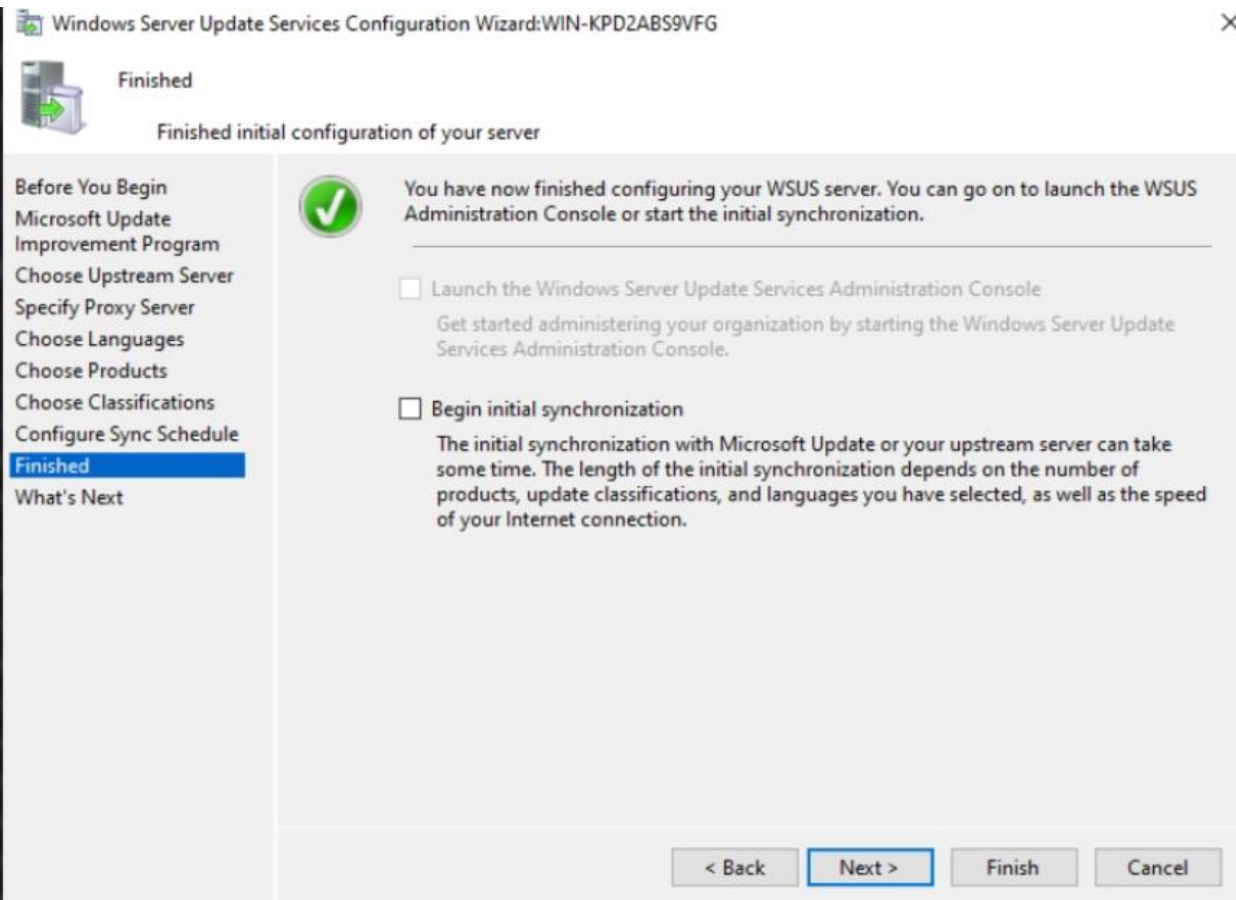


Les mises à jour peuvent être synchronisées, approuvées et déployées de manière contrôlée.



Cette approche réduit l'exposition aux vulnérabilités connues sur les postes et serveurs.

La console montre le suivi des mises à jour et leur processus d'approbation.



console WSUS avec synchronisation réussie,

fenêtre d'approbation des mises à jour.

Projet OFF

PRJ-OFF12

Audit de Sécurité d'Infrastructure

Conception · Pentest · Remédiation

Red Team

Blue Team

Wazuh

VirtualBox

2025 — 2026

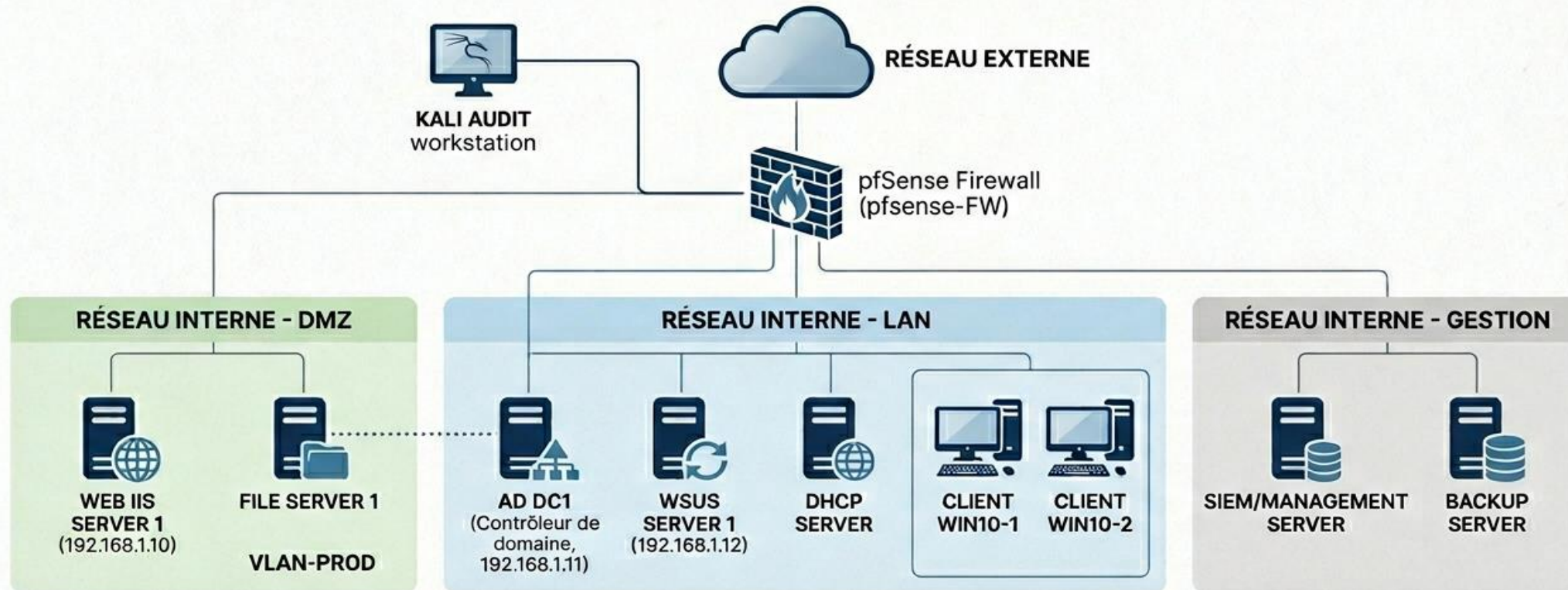


Cybersécurité

Infrastructure de départ

SCHÉMA D'INFRASTRUCTURE INITIALE (SYS-OFF12)

Mai 2026



COÛT DE L'AUDIT DE CYBERSÉCURITÉ : L'évaluation détaillée de la posture de sécurité de NeoTech, incluant la station KALI d'audit, représente un **coût total de 4.800 €**. Ce montant couvre l'analyse de l'architecture virtualisée (pfSense, AD, Web, WSUS, clients), la cartographie des vulnérabilités critiques (ex: pfSense Any-to-Any, SQLi, XSS), et l'estimation de l'impact financier, posant ainsi une base solide pour la phase de remédiation.

```
File Machine View Input Devices Help
kali@kali: ~
Session Actions Éditer Vue Aide
(kali@kali)~[~]
$ ping -c 2 192.168.1.11
ping -c 2 192.168.1.12
ping -c 2 192.168.1.20
ping -c 2 192.168.1.30
ping -c 2 192.168.1.103
ping -c 2 192.168.1.104
ping -c 2 192.168.1.1
PING 192.168.1.11 (192.168.1.11) 56(84) bytes of data.
64 bytes from 192.168.1.11: icmp_seq=1 ttl=128 time=2.76 ms
64 bytes from 192.168.1.11: icmp_seq=2 ttl=128 time=1.44 ms

— 192.168.1.11 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 1.442/2.102/2.762/0.660 ms
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
64 bytes from 192.168.1.12: icmp_seq=1 ttl=128 time=3.04 ms
64 bytes from 192.168.1.12: icmp_seq=2 ttl=128 time=1.32 ms

— 192.168.1.12 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 1.316/2.177/3.038/0.861 ms
PING 192.168.1.20 (192.168.1.20) 56(84) bytes of data.
64 bytes from 192.168.1.20: icmp_seq=1 ttl=128 time=2.68 ms
64 bytes from 192.168.1.20: icmp_seq=2 ttl=128 time=0.950 ms

— 192.168.1.20 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 0.950/1.813/2.676/0.863 ms
PING 192.168.1.30 (192.168.1.30) 56(84) bytes of data.
64 bytes from 192.168.1.30: icmp_seq=1 ttl=128 time=1.02 ms
64 bytes from 192.168.1.30: icmp_seq=2 ttl=128 time=1.11 ms

— 192.168.1.30 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 1.016/1.064/1.113/0.048 ms
PING 192.168.1.103 (192.168.1.103) 56(84) bytes of data.

— 192.168.1.103 ping statistics —
2 packets transmitted, 0 received, 100% packet loss, time 1024ms

PING 192.168.1.104 (192.168.1.104) 56(84) bytes of data.

— 192.168.1.104 ping statistics —
2 packets transmitted, 0 received, 100% packet loss, time 1004ms

PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
```

Phase 1 – Audit de pré-implémentation

Cartographie des Vulnérabilités

Type	Vulnérabilité	Note/10	Niveau
Réseau	Règles pfSense trop permissives	8/10	Élevé
Applicatif	Injection SQL	10/10	Critique
Applicatif	XSS	6/10	Moyen
Système	Serveurs Windows non à jour	10/10	Critique
Système	Mauvaise configuration Active Directory	9/10	Critique

Choose what to do with packets that match the criteria specified below.
Hint: the difference between block and reject is that with reject, a packet (TCP RST or ICMP port unreachable for UDP) is returned to the sender, whereas with block the packet is dropped silently. In either case, the original packet is discarded.

Action ☐ Pass ☐ Block ☐ Reject

Disabled ☐ Disable this rule
Set this option to disable this rule without removing it from the list.

Interface LAN
Choose the interface from which packets must come to match this rule.

Address Family IPv4
Select the Internet Protocol version this rule applies to.

Protocol Any
Choose which IP protocol this rule should match.

Source

Source ☐ Invert match any Source Address /

Destination

Destination ☐ Invert match any Destination Address /

Extra Options

Log ☐ Log packets that are handled by this rule
Hint: the firewall has limited local log space. Don't turn on logging for everything. If doing a lot of logging, consider using a remote syslog server (see the Status: System Logs: Settings page).

Description
A description may be entered here for administrative reference. A maximum of 52 characters will be used in the ruleset and displayed in the firewall log.

Advanced Options [Display Advanced](#)

Firewall Rules: x +

https://192.168.1.1/firewall_rules.php?if=lan

ewall / Rules / LAN

ing WAN LAN

es (Drag to Change Order)

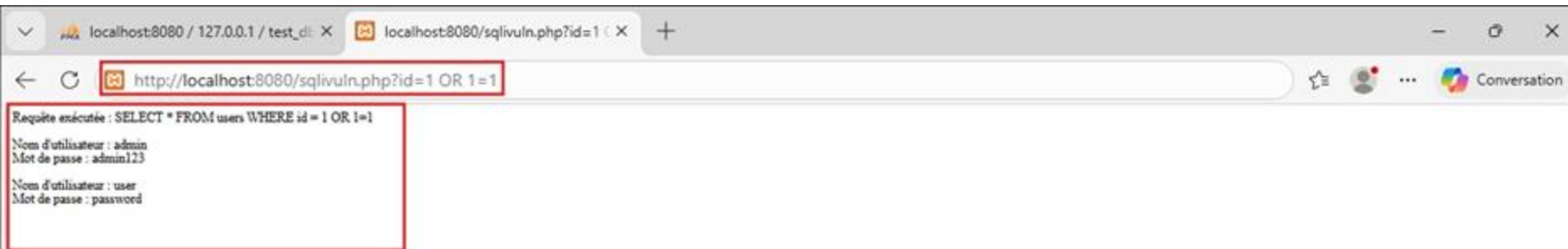
States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
3 / 4.14 MiB	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	⚙️
26 / 206.13 MiB	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	📌 ✎️ 📄 🚫 🗑️
0 / 0 B	IPv6 *	LAN net	*	*	*	*	none		Default allow LAN IPv6 to any rule	📌 ✎️ 📄 🚫 🗑️

↑ Add ↓ Add 🗑️ Delete 💾 Save ➕ Separator

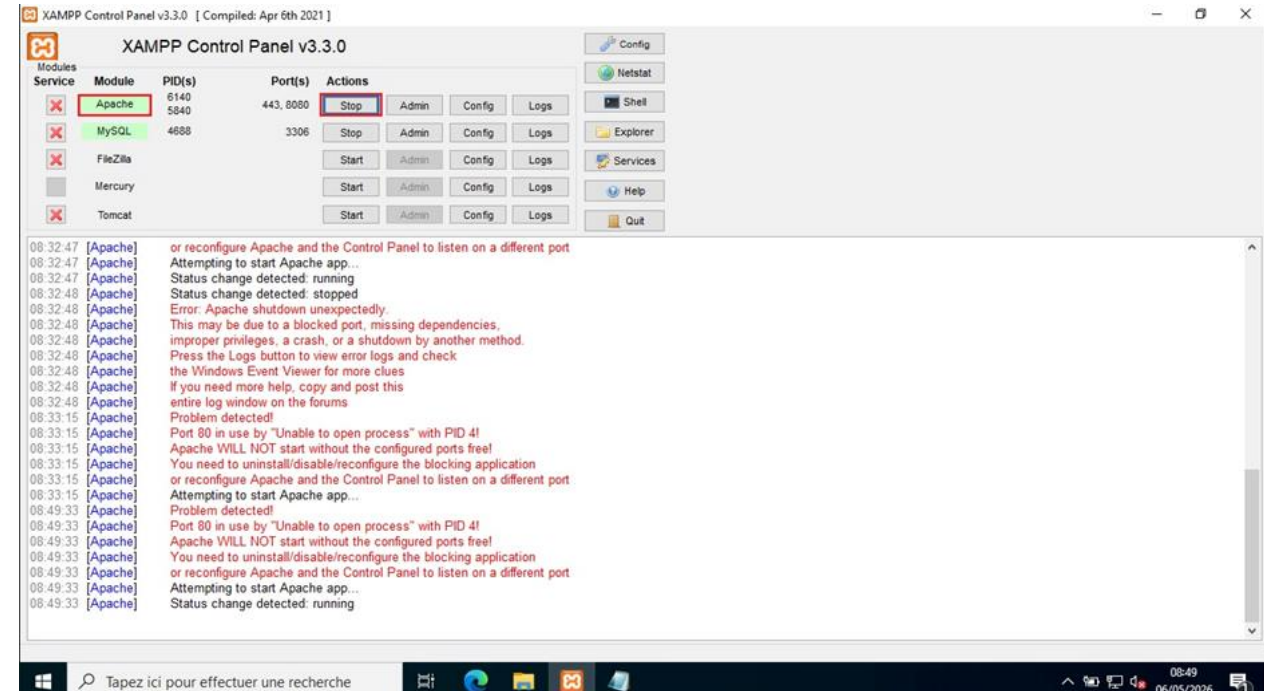
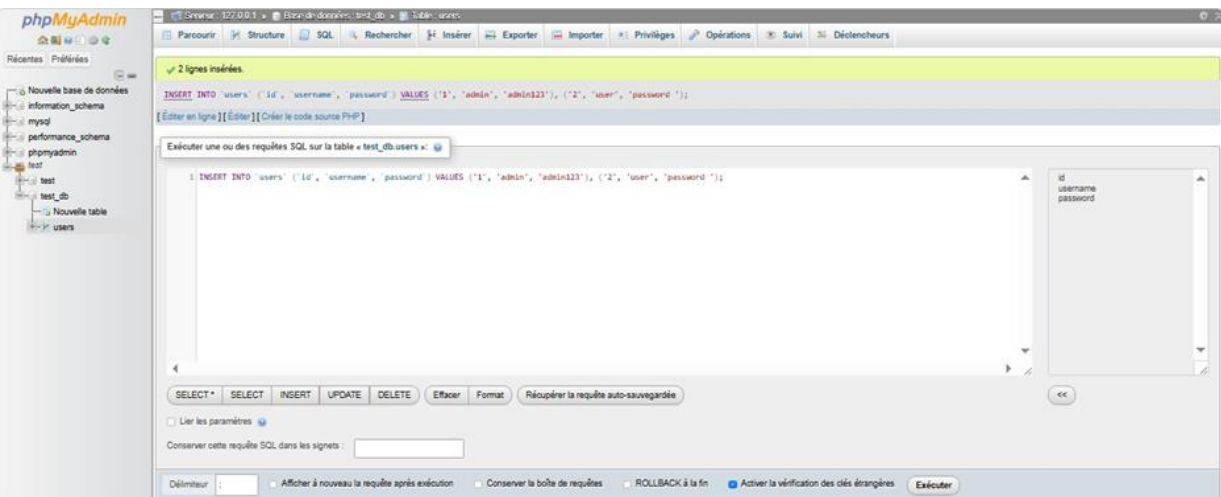
Vulnérabilité réseau – Open Door

Compromission d'un poste = Accès global

Vulnérabilité applicative – Injection SQL



Base de données lancer via XAMPP



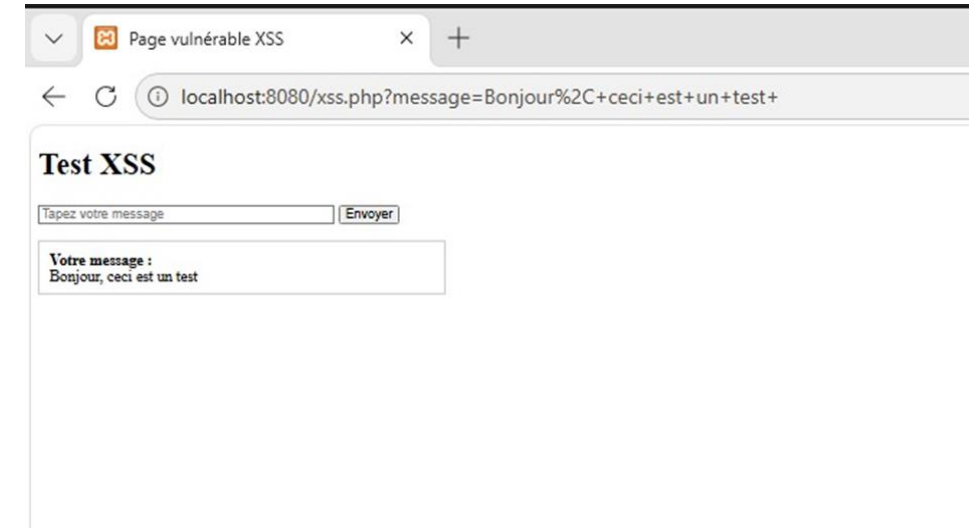
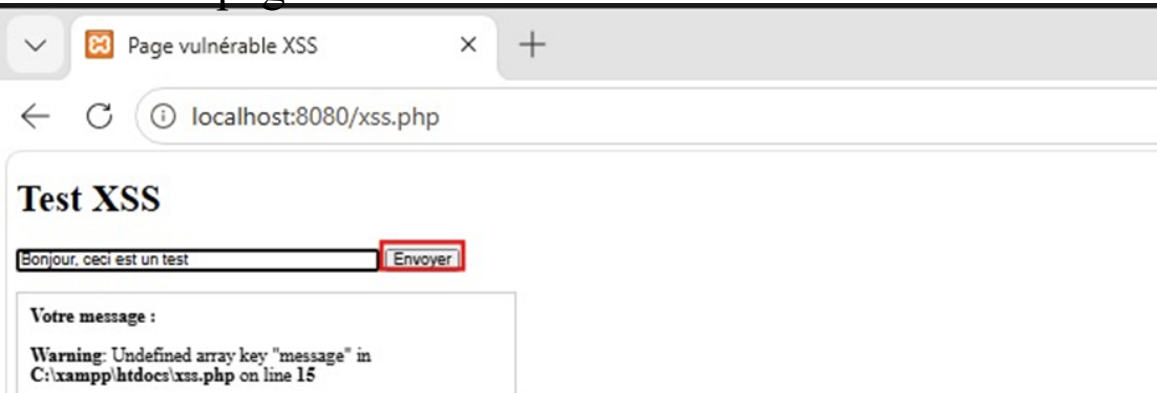
Vulnérabilité applicative – Injexion XSS

Code Javascript malveillant

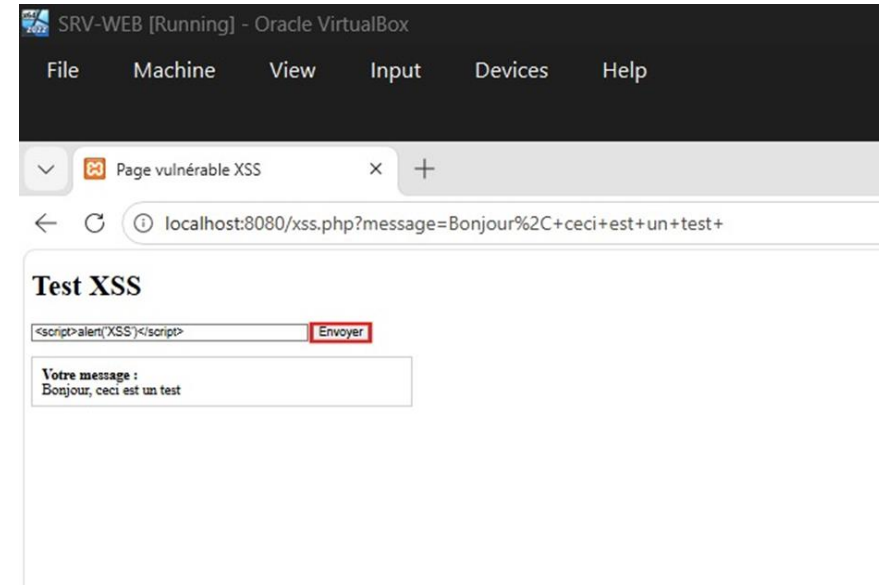
```
SRV-WEB [Running] - Oracle VirtualBox
File Machine View Input Devices Help

*Sans titre - Bloc-notes
Fichier Edition Format Affichage Aide
<!DOCTYPE html>
<html>
<head>
<title>Page vulnérable XSS</title>
</head>
<body>
<h1>Test XSS</h1>
<form method="GET">
<input type="text" name="message" placeholder="Tapez votre message" style="width: 300px;">
<button type="submit">Envoyer</button>
</form>
<br>
<div style="border:1px solid #ccc; padding:10px; width:400px;">
<strong>Votre message :</strong><br>
<?php echo $_GET['message']; ?>
</div>
</body>
</html>
```

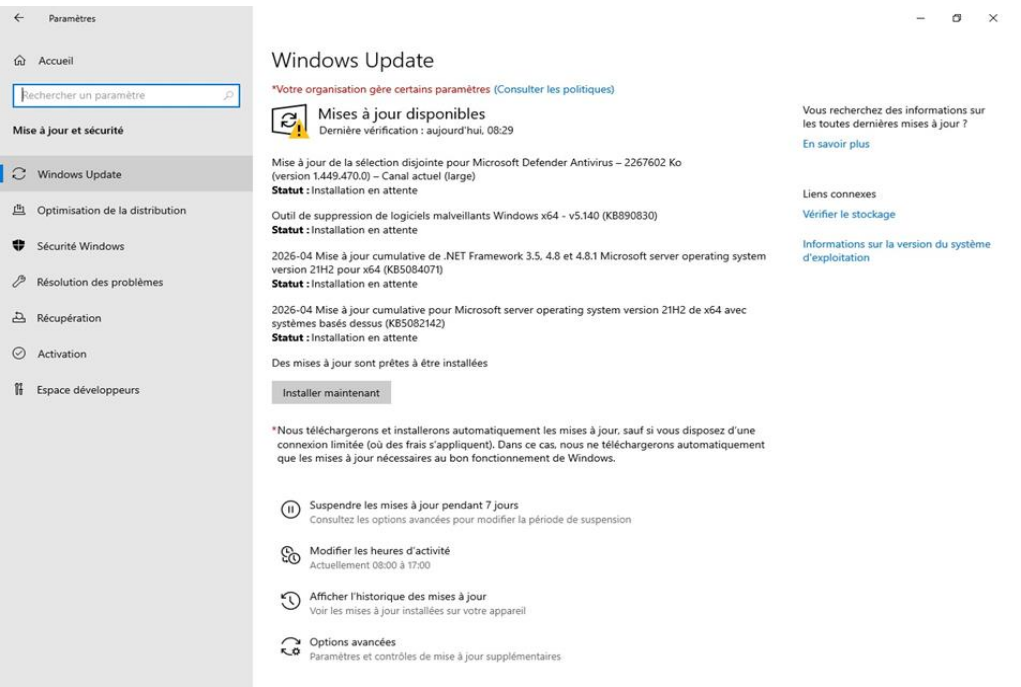
Test de la page Web



Injection du code XSS sur la page web

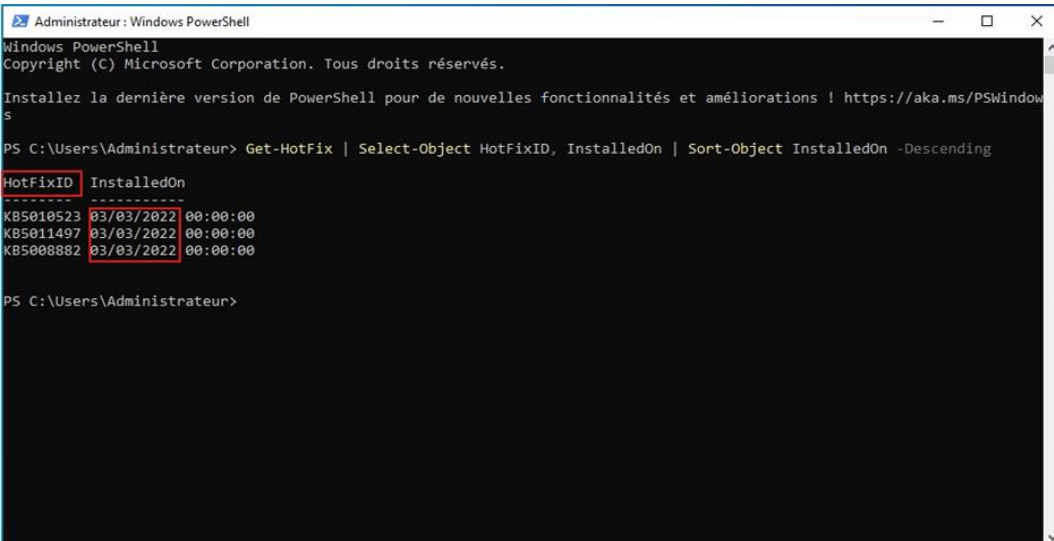


Vulnérabilité système - Serveur Windows non mis à jour



Mise à jour cumulative KB5082142

Suppression de logiciel malveillants KB508407



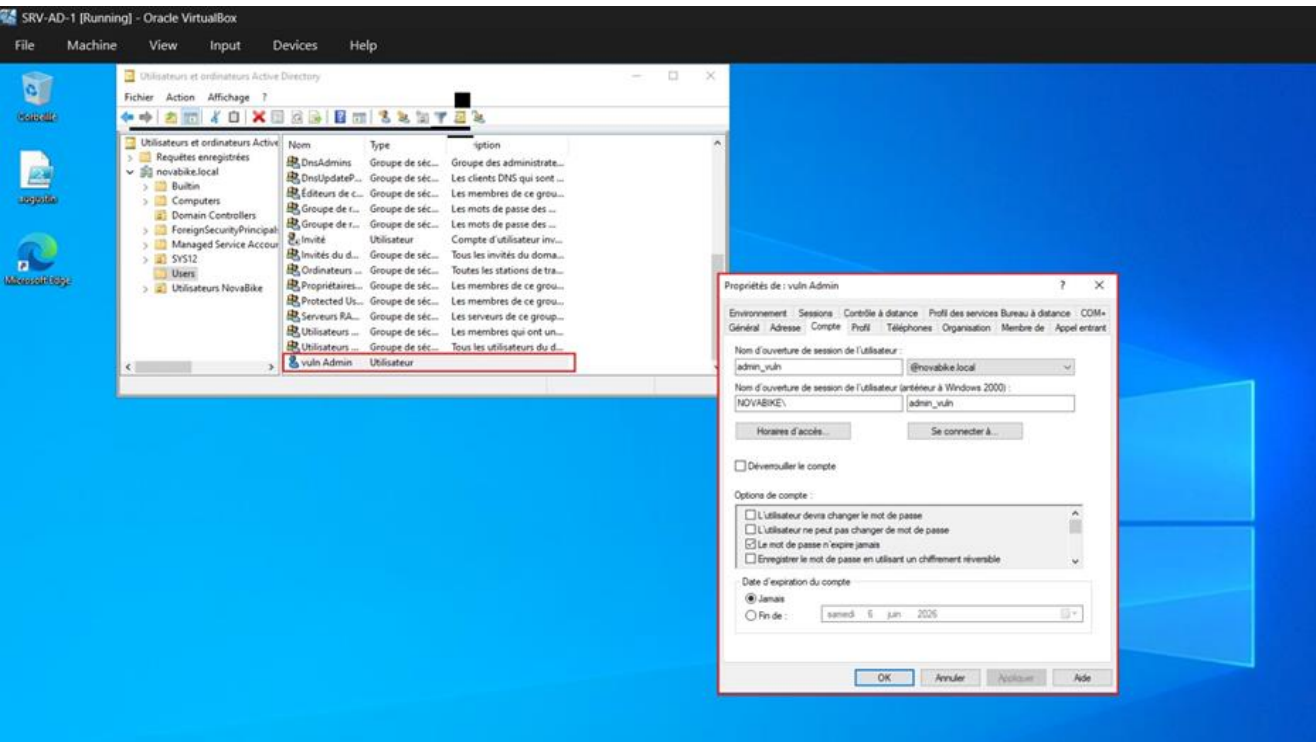
Get-Hotfix

CVE-2024-38063 (RCE sur pile TCP/IP)

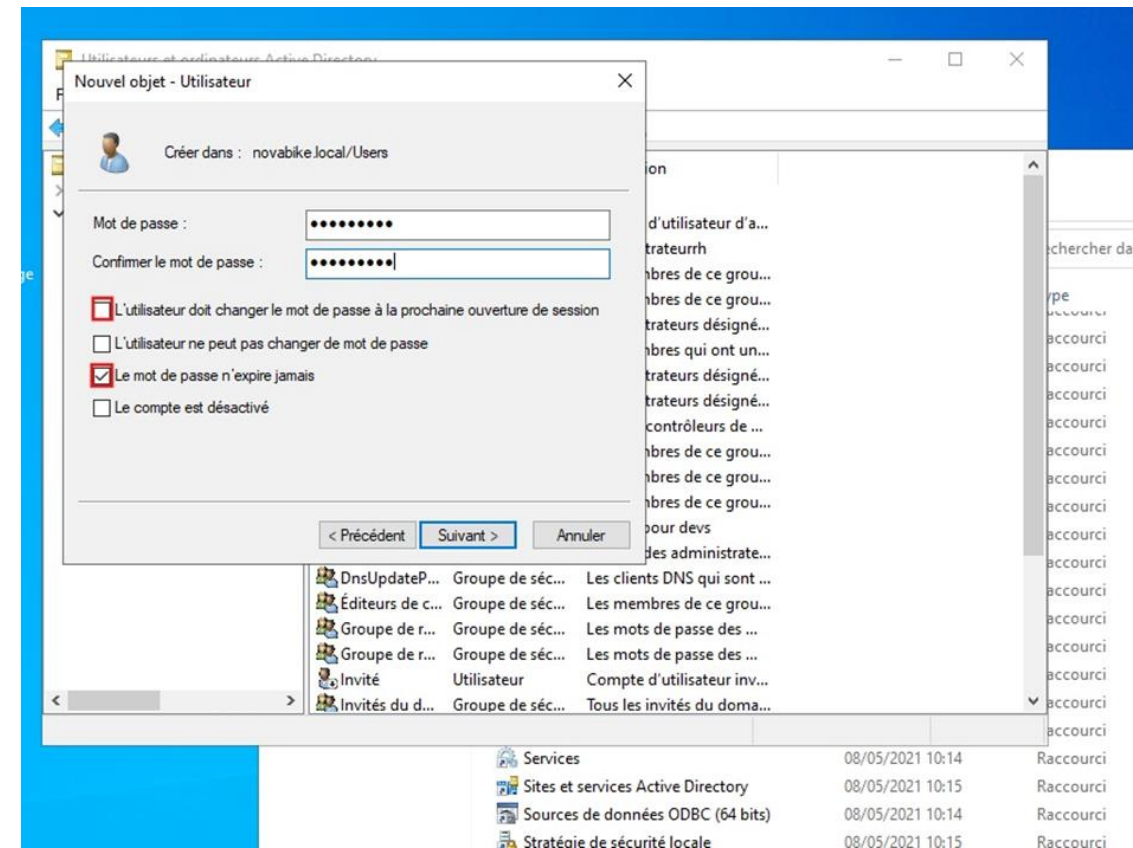
CVE-2024-21302 (contournement VBS).

Vulnérabilité 5 – Mauvaise configuration Active Directory

Mot de passe: Passer@2026



Mot de passe: Admin1234



Membre du groupe Domain Admins

Politique de complexité de mot de passe

Stratégie de remédiation

Type	Vulnérabilité Identifiée	Stratégie de Remédiation
Réseau	Règle Any-to-Any sur pfSense	Suppression de la règle + Filtrage strict par IP/port.
Applicatif	Injection SQL (SQLi)	Intégration de requêtes préparées (bind_param).
Applicatif	Faible Cross-Site Scripting (XSS)	Échappement des entrées avec htmlspecialchars().
Système	Défaut de Patching (SRV-AD-1)	Installation immédiate des KBs (ex: KB5082142).
Système	Compte admin_vuln faible	Suppression du compte + GPO de complexité forcée.



ANALYSE FINANCIÈRE : AUDIT & REMÉDIATION (MAI 2026)

COÛTS D'IMPACT POTENTIELS (COMPROMISSION TOTAL)

4 800 000 €



Pertes d'exploitation (Downtime)

Interruption des services, perte de productivité, clients impactés.



Amendes RGPD

Sanctions réglementaires pouvant atteindre 4 % du CA annuel mondial.



Remédiation post-incident

Forensique, restauration, communication de crise, renforcement d'urgence.

COMPARAISON DES COÛTS



STRATÉGIE PROACTIVE DE SÉCURISATION

7 300 €



Audit Initial (6 jours - 800€/j)

4 800 €

Évaluation complète de l'architecture, tests d'intrusion, analyse des vulnérabilités et priorisation des risques.



Remédiation & Durcissement **2 500 €**

Correction des failles critiques, durcissement des systèmes, bonnes pratiques et recommandations de sécurité.



BILAN : Investir 7 300 € dans l'audit et le durcissement permet de **neutraliser un risque financier de 4,8 millions d'euros.**

La cybersécurité est un investissement stratégique de viabilité pour NeoTech.



Conclusion

MERCI POUR VOTRE ATTENTION!